

WiFi protocol(2)

20210741 황정현

목차

- 802.11 프레임 구조와 기초 공격 시나리오
- WiFi 연결 수립 과정
- 802.11 암호화 방법(WEP, WPA, WPA2, WPA3) 및 취약점

802.11 프레임 구조

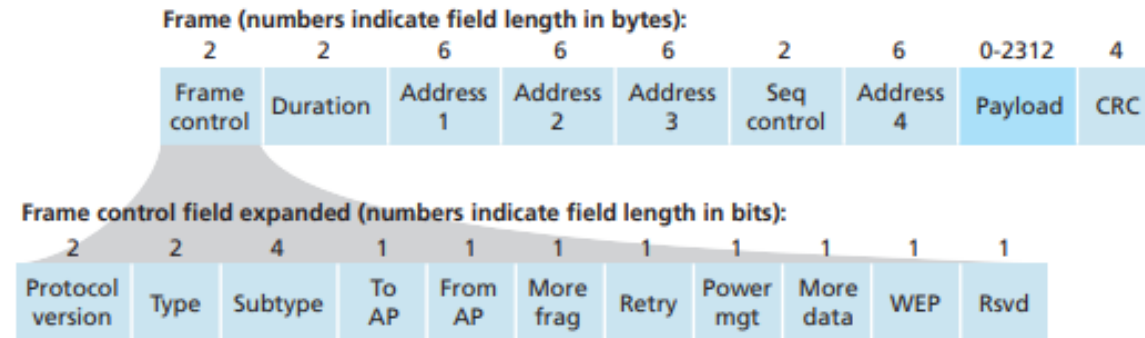


Figure 7.13 ♦ The 802.11 frame

- 취약점: 관리 프레임의 비암호화
 - > Header(MAC 주소 포함)가 평문으로 전송됨
 - > Management Frame이 암호화 되거나, 인증되지 않음.

Management Frame: Beacon, Probe, Deauthentication, Disassociation

MAC Spoofing & Deauthentication Attack

A. 공격 매커니즘

- 위조된 프레임을 생성하여 전파시킴.
- Frame Structure
 - Type: 00 (Management Frame)
 - Subtype: 1100 (Deauthentication, 0xC)
 - Source MAC: AP의 MAC 주소(Spoofing)
 - Destination MAC: 피해자의 MAC 주소 혹은 브로드캐스트

MAC Spoofing & Deauthentication Attack

B. 공격 시나리오

1. Targeting: 해커가 공기 중을 감청하다가 목표를 정함.
2. Injection: 해커가 자신의 MAC 주소를 AP로 위조(spoofing)하여 피해자에게 Deauth 프레임을 계속 쏘아보냄.
3. Disconnection: 피해자의 단말기는 진짜 AP가 연결을 종료시킨 줄 알고 연결을 종료함.
4. Re-connection: 피해자는 자동으로 AP에 재접속을 시도함.
5. Capture: 4-way Handshake 과정이 다시 일어나고, 해커는 이 메시지를 캡처하여 다른 공격에 활용함.

MAC Spoofing & Deauthentication Attack

C. 방어법

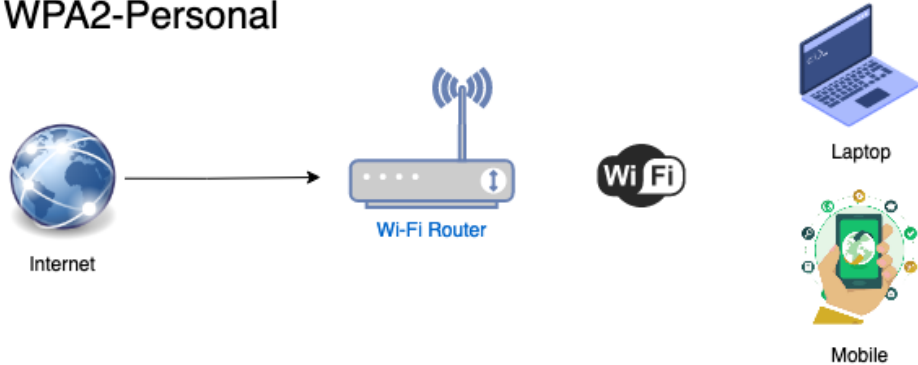
- 802.11w (MFP – Management Frame Protection)
 - 관리 프레임에도 MIC를 붙이고 암호화함.
 - 해커가 위조 패킷을 보내도 MIC 검증에 실패하여 단말기가 무시할 수 있음.
 - WPA3부터는 필수적으로 관리 프레임을 암호화하기 때문에 안전하다고 볼 수 있음.

WiFi Connection Steps

- 1단계: Scanning
- 2단계: Association
- 3단계: RSN Authentication – EAP/PSK
- 4단계: 4-way Handshake
- 5단계: Data Encryption – WEP/TKIP/CCMP/GCMP

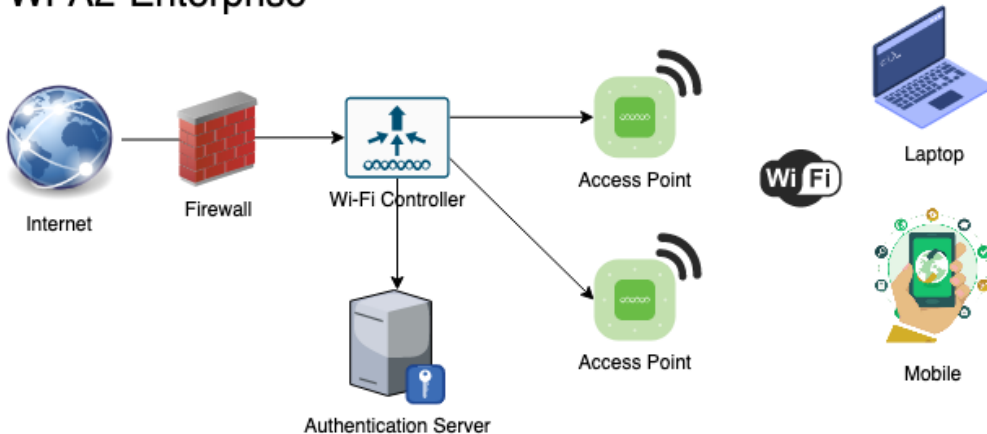
Personal vs. Enterprise

WPA2-Personal



- Personal: 공유기가 인증 과정을 모두 다 맡아서 함.

WPA2-Enterprise



- Enterprise: Radius 서버(AS)를 거쳐서 인증 과정이 발생. 이때 EAP 프로토콜을 사용함.

EAP & EAPOL

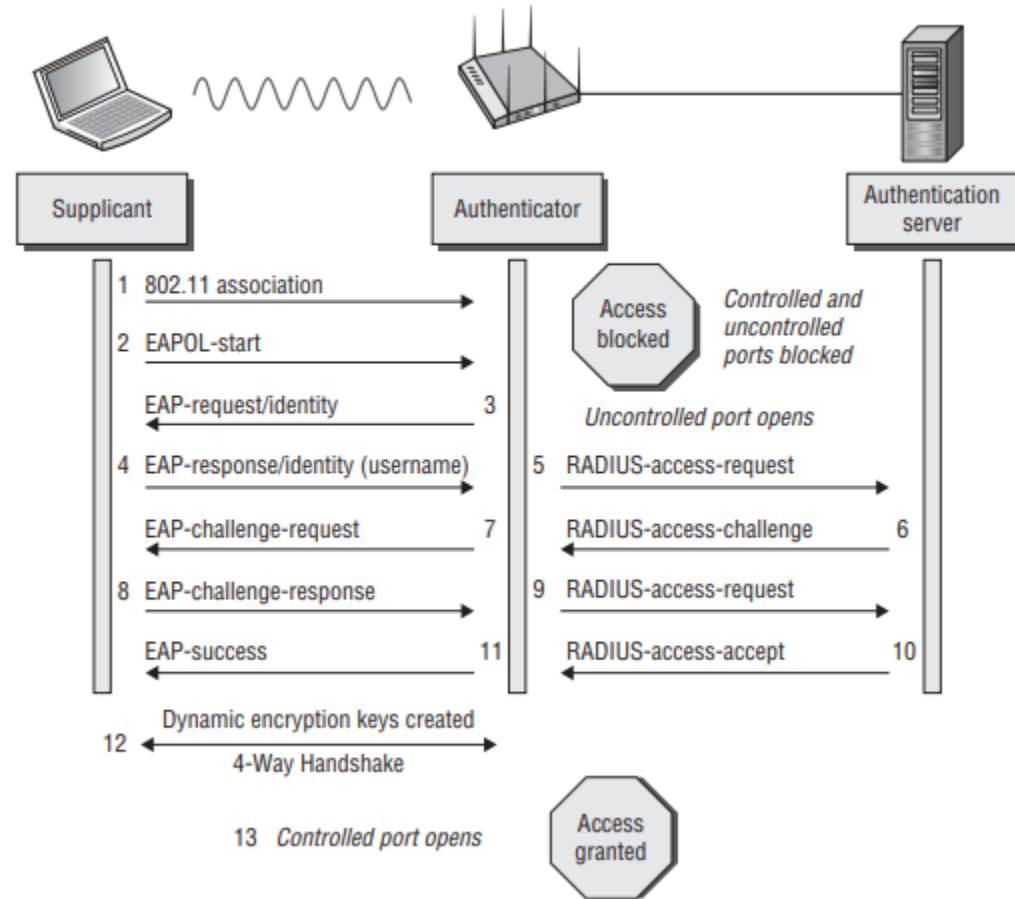
1. EAP (Extensible Authentication Protocol)

- 정의: 다양한 인증 방식을 수용하는 유연한 인증 프레임워크
- 특징:
 - 1) 특정 인증법을 강제하지 않음(Container 구조)
 - 2) 필요에 따라 모듈 교체 가능(ex. EAP-TLS, PEAP 등)

2. EAPOL (EAP over LAN)

- 정의: EAP 메시지를 MAC 계층에서 전송하기 위한 캡슐화 프로토콜
- 역할:
 - 1) IP 주소가 없는 상태에서 인증 데이터 운반
 - 2) Supplicant <-> AP 구간의 프로토콜

802.1X Protocol Conversion & Data Flow



1. 프로토콜

- Supplicant <-> Authenticator : EAPOL 프로토콜
- Authenticator <-> Server : RADIUS 프로토콜

2. Key Mechanism

- AP의 역할: 단순 중계자
- EAPOL은 EAP 뿐만 아니라 이후 4-way handshake에서도 사용됨.

정적 키와 동적 키

- 정적 키(Static Key)
: 입력한 비밀번호를 그대로 암호화 키로 사용함. 키가 변하지 않으므로 해커가 시간을 들이면 키를 알아내기 쉬움.
예시) WEP
- 동적 키(Dynamic Key)
: 입력한 비밀번호를 재료로 매 세션마다 4-Way Handshake를 통해 새로운 동적 키를 생성해 암호화 키로 사용.
예시) WPA/WPA2/WPA3

4-way Handshake

A. 용어 정리

- PSK(Pre-Shared Key): 와이파이 비밀번호 + SSID를 조합해 생성
- PMK(Pairwise Master Key): 최상위 비밀키(Personal의 경우 PSK, Enterprise의 경우 인증 서버가 준 키)
- Anonce(Authenticator Nonce): AP가 만든 nonce
- Snonce(SupPLICant Nonce): 단말기가 만든 nonce
- AA(Authenticator Address): AP의 MAC 주소
- SPA(SupPLICant Address): 단말기의 MAC 주소
- **PTK = PRF(PMK, Anonce, Snonce, AA, SPA)**

4-way Handshake

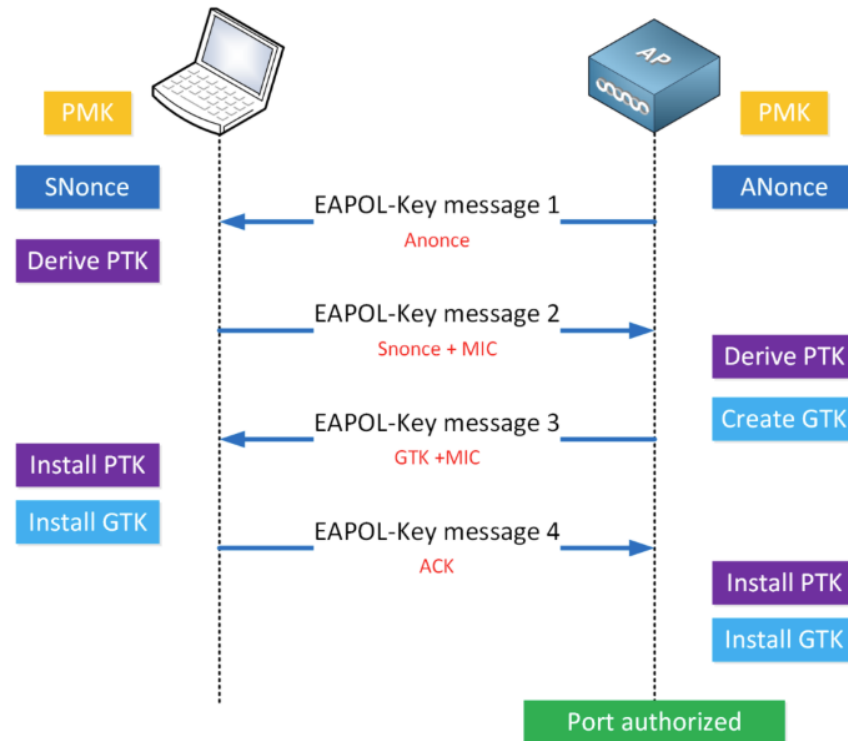
B. 동작 과정

[Message 1] AP -> Client

- 내용: Anonce
- 암호화: 평문
- 상태:

AP – Snonce가 필요함.

Client – PTK 생성할 재료를 모두 수집한 상황. PTK를 생성함.

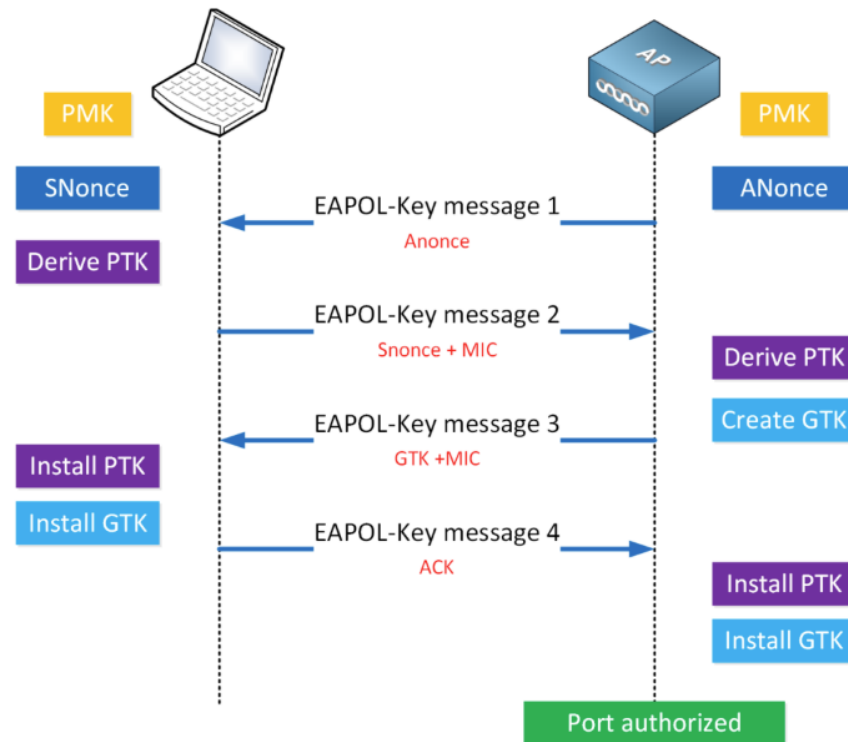


4-way Handshake

B. 동작 과정

[Message 2] Client -> AP

- 내용: Snonce + MIC
- 암호화: 평문 + MIC
- 핵심 원리(MIC): Client가 PTK로 서명(MIC)을 해서 보냄.
- 상태:
AP – PTK를 생성하고, MIC를 계산해서 확인함.

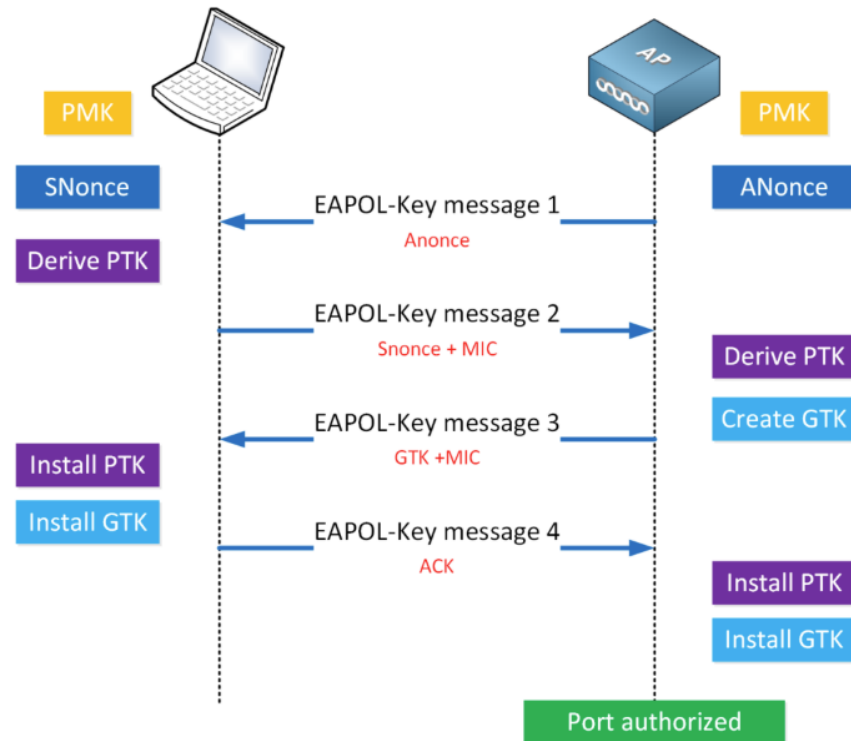


4-way Handshake

B. 동작 과정

[Message 3] AP -> Client

- 내용: GTK(Group Key) + MIC
- 암호화: 암호화됨.
- Broadcast용 키(GTK)를 AP가 만들어서 PTK로 암호화하여 보냄.

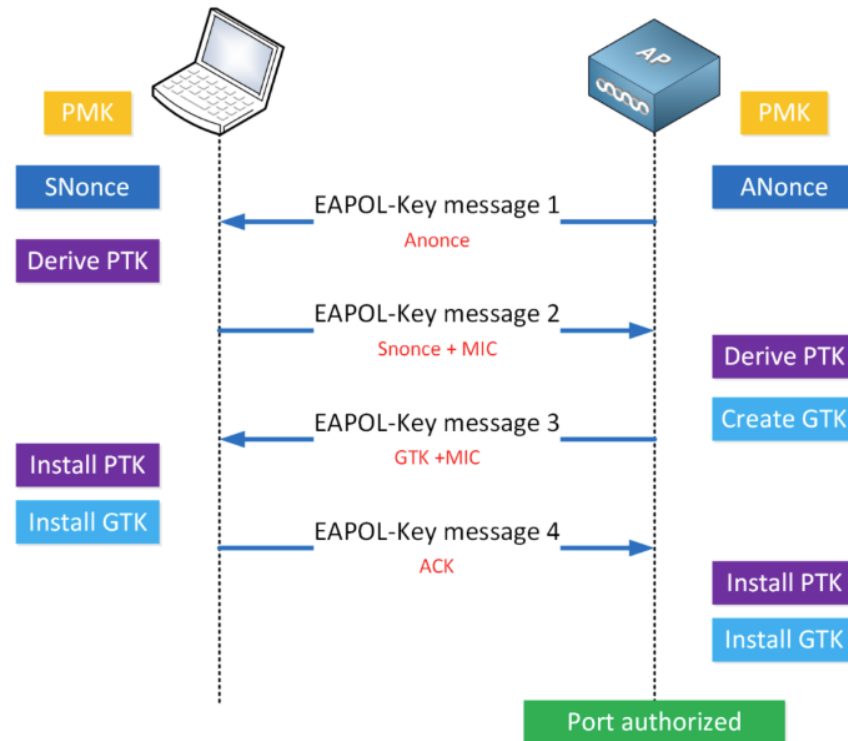


4-way Handshake

B. 동작 과정

[Message 4] Client -> AP

- 내용: ACK
- 암호화: 암호화됨.
- 키를 모두 확인했다는 의미의 패킷. 키 교환이 완료되고 실제 데이터 통신이 시작됨.



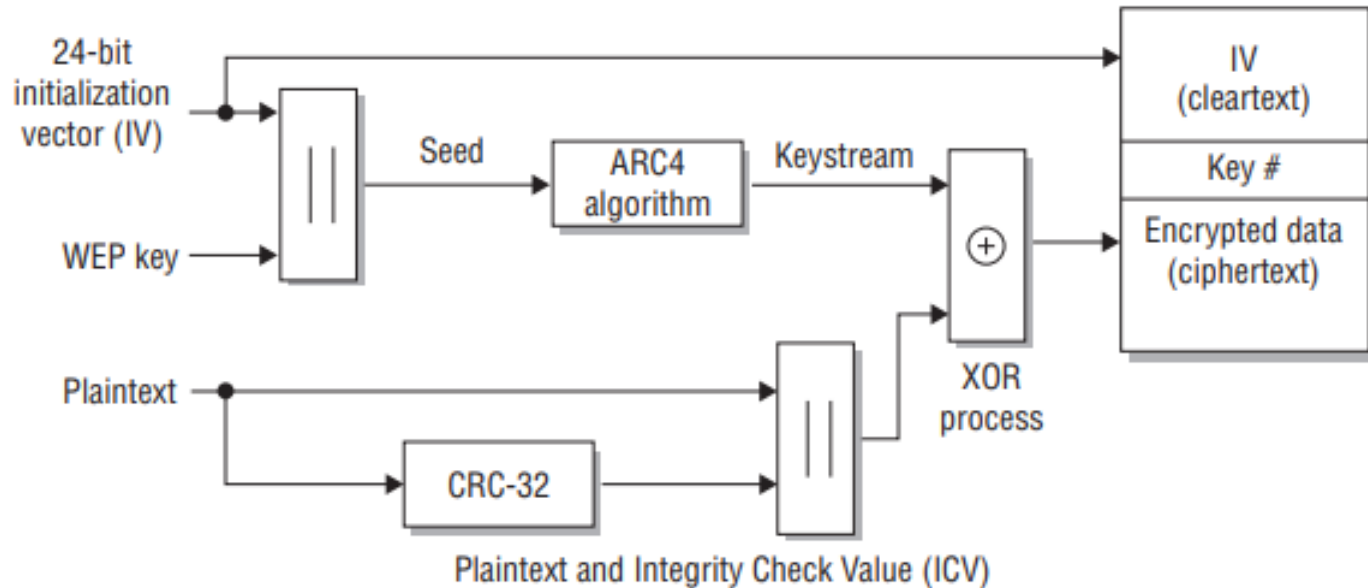
Legacy Security

- WEP
- WPA/TKIP

WEP

- ARC4 알고리즘을 기반으로 하는 스트림 암호 방식
- 핵심 수식

$$C = (P \parallel ICV) \oplus ARC4(IV \parallel K)$$

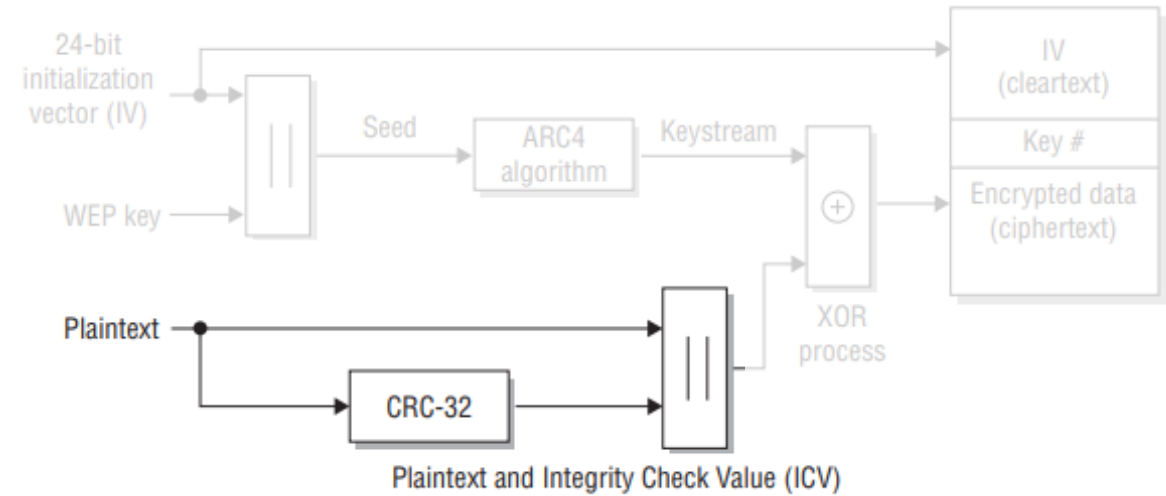


WEP

- **WEP encryption process**

1. 무결성 값(ICV) 계산

CRC-32 알고리즘으로 체크섬 계산하여 평문 뒤에 붙임.



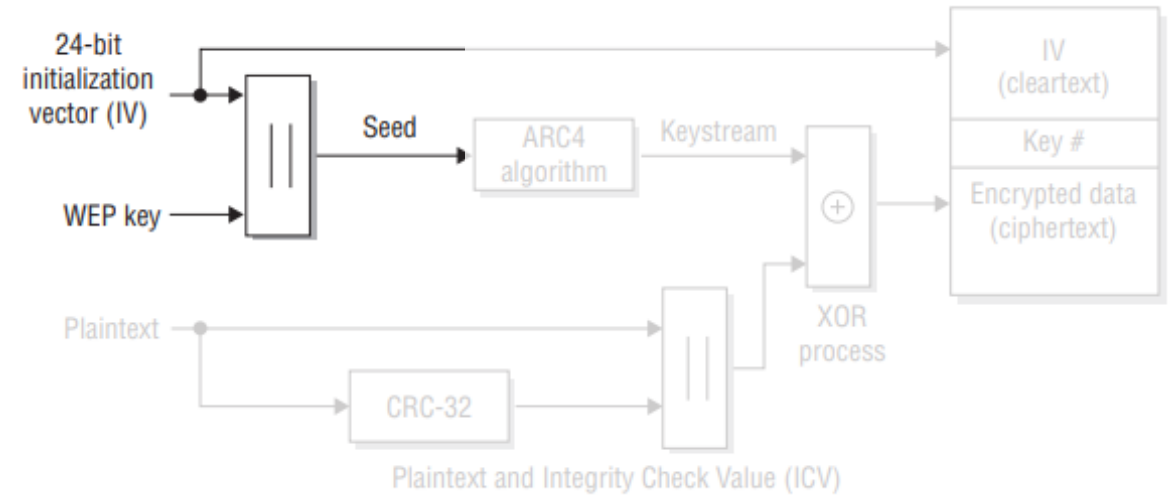
$$P' = P \parallel \text{CRC32}(P)$$

WEP

- **WEP encryption process**

2. 시드 (Seed) 생성

IV를 만들어 Seed를 만든다. 고정된 Key 대신 매번 IV를 랜덤하게 설정하여 암호화 패턴을 다르게 만든다.



$$\text{Seed} = \text{IV} \parallel \text{Key}$$

64-bit WEP

24-bit IV	40-bit static key
-----------	-------------------

128-bit WEP

24-bit IV	104-bit static key
-----------	--------------------

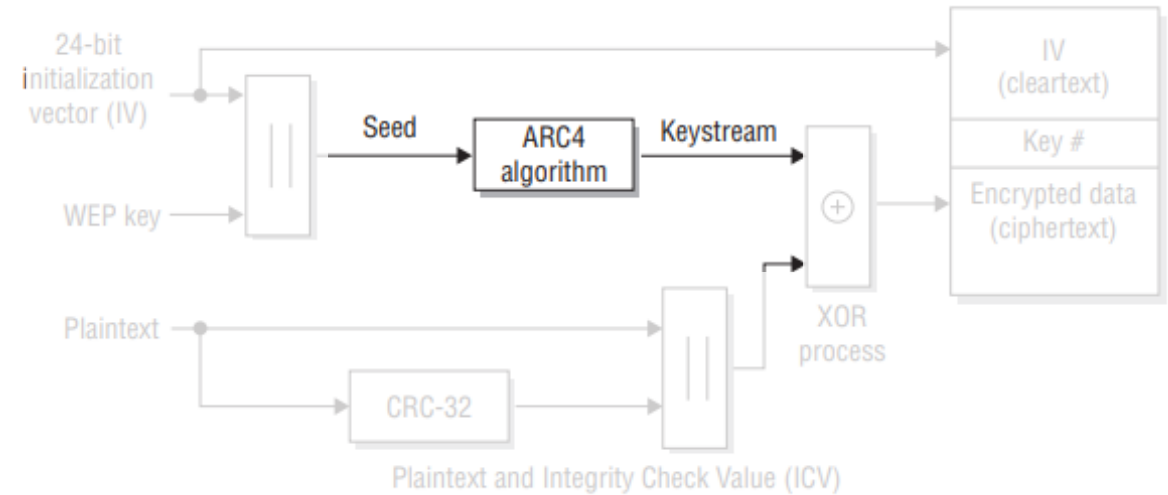
WEP

- **WEP encryption process**

3. 키 스트림(Keystream) 생성

Seed를 바탕으로 ARC4 알고리즘을 사용해 데이터 길이만큼의 난수열(Keystream)을 생성함.

$$KS = \text{ARC4}(\text{Seed})$$



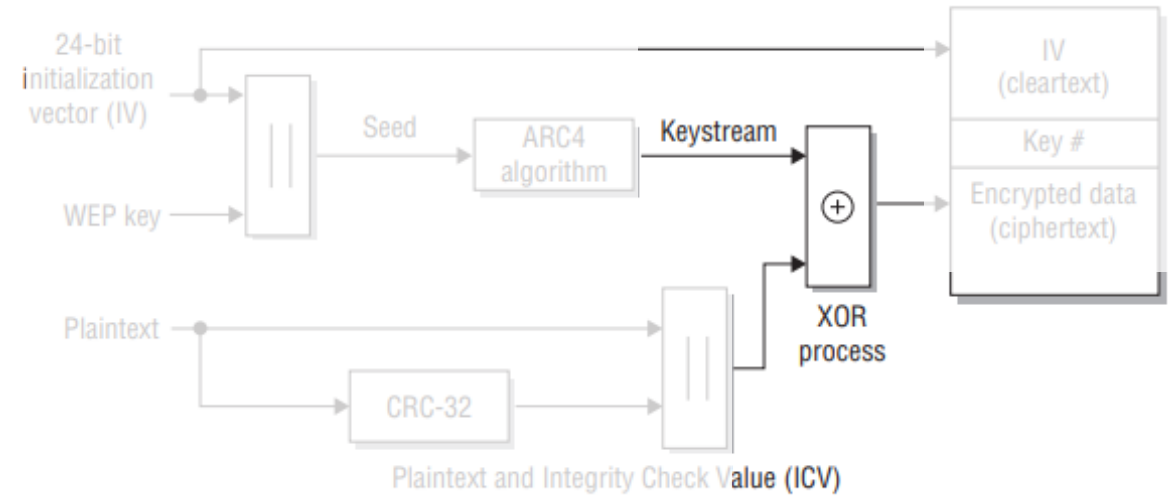
WEP

- **WEP encryption process**

4. 암호화 (XOR)

생성된 Keystream과 데이터(P')를 비트 단위로 XOR한다.

$$C = P' \oplus KS$$



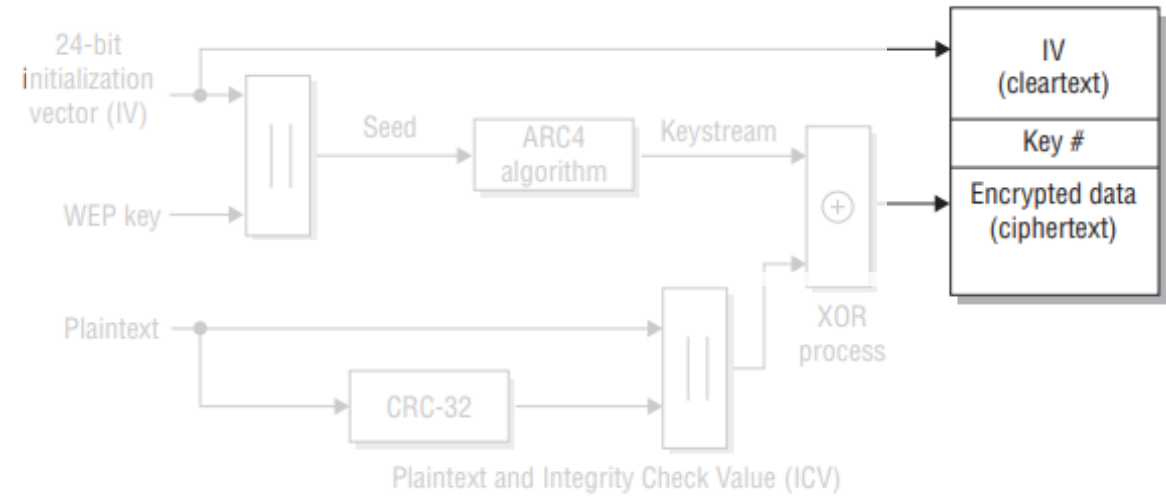
WEP

- **WEP encryption process**

5. 전송

최종적으로 상대방에게 전송하는 프레임은 다음과 같다.

Frame = Header || IV || KeyID || Ciphertext



WEP

- **WEP 방식의 한계**

1. IV Collision Attack – IV 공간의 한계.
2. Weak Key Attack – ARC4 알고리즘의 결함.
3. Reinjection Attack – 해커의 데이터 수집.
4. Bit-Flipping Attack – CRC 알고리즘의 한계.

WPA (Wi-Fi protected Access)

- WEP을 보완하기 위해 만든 임시 보안 솔루션.
- 하드웨어 교체 없이 펌웨어 업그레이드만으로 보안 강화.
- 핵심 변화:
 - 1) 인증 강화: 802.1X(EAP) 도입
 - 2) 키 관리 강화: 4-way Handshake 도입
 - 3) 암호화 프로토콜 개선: WEP -> TKIP

TKIP (Temporal Key Integrity Protocol)

- 개선점

1. Temporal Keys (동적 키)

4-way Handshake를 통해 세션마다 다른 동적키(128bit Temporal Key) 사용.

2. Sequencing (순서 지정)

TSC(TKIP Sequence Counter)라는 48비트 카운터를 모든 패킷에 부여
순서가 맞지 않으면 무시(재전송 공격 차단)

3. Key Mixing (키 혼합)

IV 충돌과 Weak key 공격을 막기 위해 복잡한 Mixing 과정 도입

4. Enhanced Data Integrity (데이터 무결성 강화)

MIC(Message Integrity Code), 일명 Michael을 도입

TKIP

• 핵심 기작

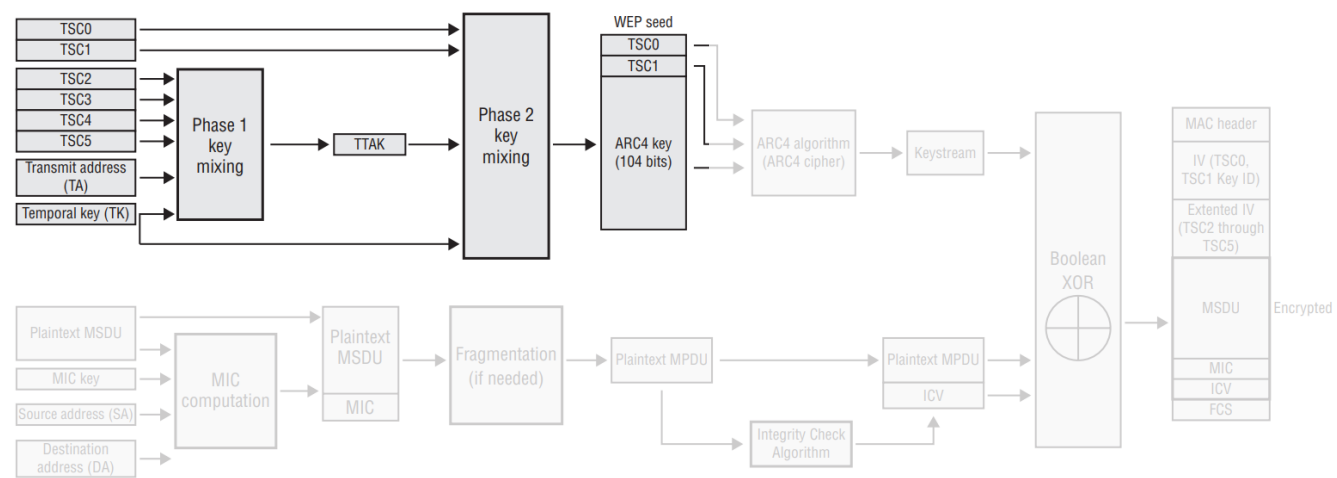
A. Key Mixing Process

TK를 그대로 사용하지 않고, 패킷마다 다른 WEP Seed로 변환

TTAK = Phase 1 (TK, TA, TSC)

WEP seed = Phase 2 (TTAK, TK, TSC)

결과적으로 매번 다른 WEP seed가 ARC4 알고리즘에 사용됨.



TKIP

• 핵심 기작

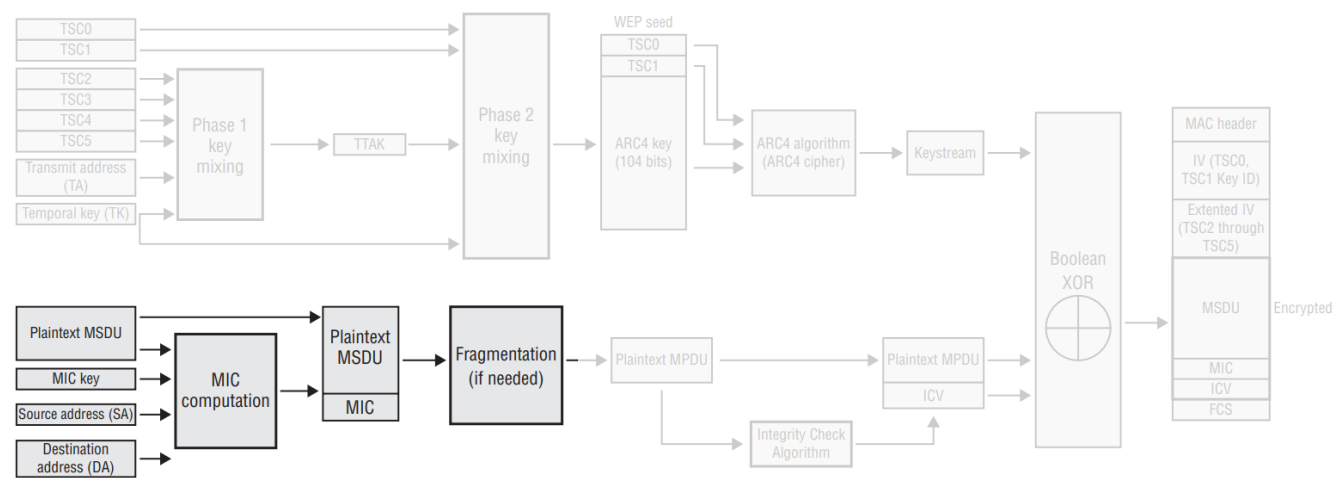
B. MIC & Countermeasures

Michael: 소스/목적지 주소, MIC key, 평문 데이터를 가지고 64비트 해시값을 만들어 데이터 뒤에 붙임.

취약점: Michael은 20비트 정도의 보안 강도를 가짐 -> Brute-force

Countermeasures: Michael이 뚫릴 것을 대비한 규칙

1. Logging: MIC 실패 시 로그를 남김.
2. 60초 shutdown: 60초 내에 MIC 실패가 2번 발생하면 60초동안 모든 통신을 차단. -> DoS 취약점
3. Rekey: 새로운 키(PTK/GTK)를 다시 생성.



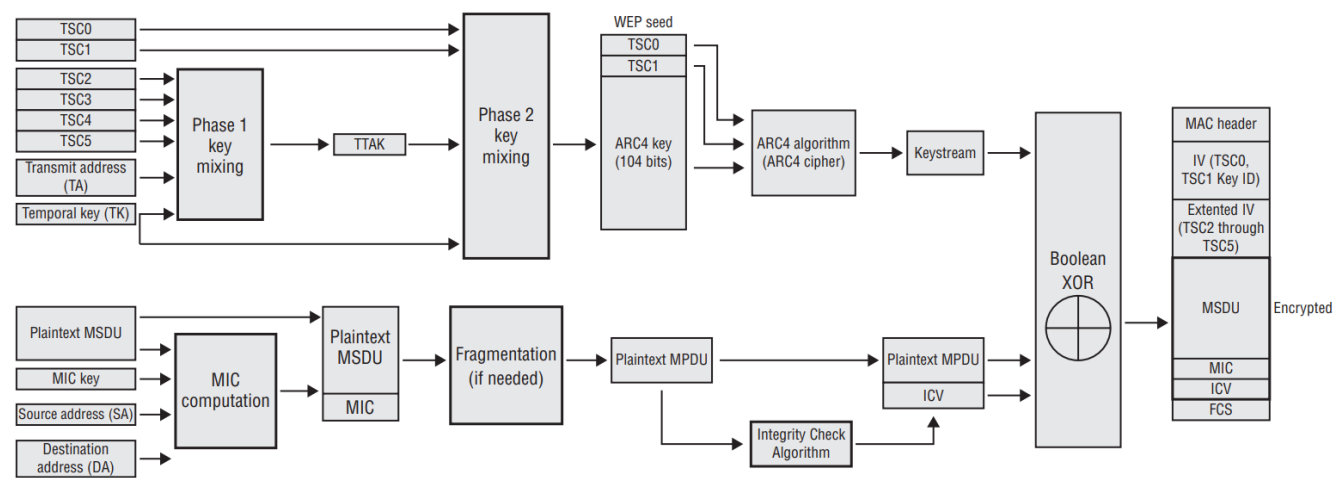
TKIP

• 핵심 기작

C. 패킷 처리 순서

수신자가 패킷을 검증할 때 다음 순서로 검증함.

1. FCS(CRC-32) 검사(전송 중 비트 오류 검사)
2. ICV 검사(WEP 무결성 체크)
3. TSC 검사(카운터 확인 / 재전송 공격 방지)
4. MIC 검사(위변조 검사)



RSN (Robust Security Network)

- WPA2/CCMP
- WPA3/GCMP, SAE

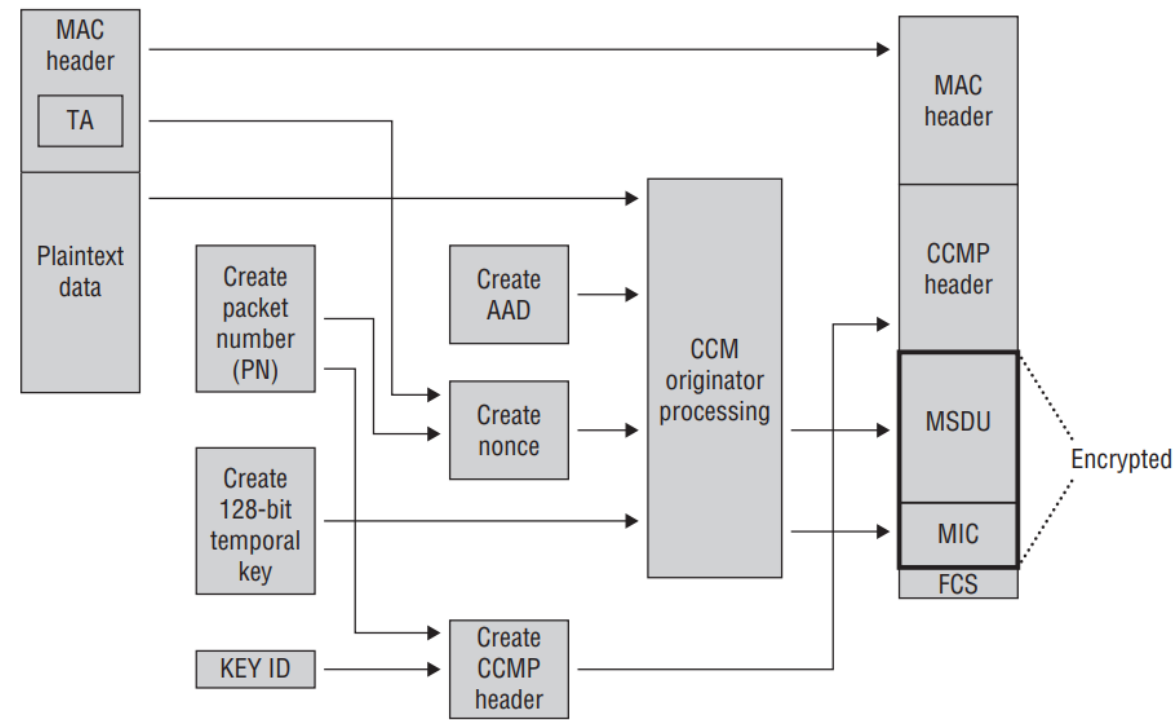
WPA2

- IEEE 802.11i 표준 보안 규격
- 핵심 변화
 - 1) TKIP(ARC4) 알고리즘 퇴출
 - 2) AES 알고리즘 의무화
 - 3) CCMP(Counter Mode with Cipher Block Chaining Message Authentication Code Protocol) 사용

CCMP

A. 구성 요소

- Temporal Keys: PTK 또는 GTK
- Packet Number(PN)
- Nonce: PN, TA(송신자 주소) 등으로 한 번만 생성.
- AAD (Additional Authentication Data): MAC 헤더의 일부 필드를 가져와서 구성, 헤더의 무결성 검증에 활용



CCMP

B. 암호화 프로세스

Step 1. 입력값 준비 & Nonce 생성

- Temporal Keys (TK): 128bit
- Packet Number (PN): 48bit
- Plaintext (P): 상위 레이어 데이터
- AAD: MAC 헤더
- Nonce = Priority(8b) || SourceAddress(48b) || PN(48b)

CCMP

B. 암호화 프로세스

Step 2. AAD 구성

- MAC 헤더를 사용하여 제작.
- 포함: Frame Control, Address1/2/3, Sequence Control 등
- 제외(Masking): 전송 중 변하는 값은 0으로 채움.

CCMP

B. 암호화 프로세스

Step 3. MIC 생성 (AES-CBC)

- 8 byte MIC을 계산.
- 데이터 블록을 $B_0, B_1, \dots, B_n$ 이라 할 때,
 - 1) 첫 블록 암호화: $X_1 = E_K(B_0)$
 - 2) Chaining: $X_{i+1} = E_K(X_i \oplus B_i)$
 - 3) 최종 결과물 중 상위 64 bit 추출
-> $MIC = MSB_{64}(X_{final})$
- 원본 데이터(P)와 헤더(AAD) 중 비트 하나만 바뀌어도 MIC 값이 완전히 바뀜.

CCMP

B. 암호화 프로세스

Step 4. 데이터 및 MIC 암호화 (AES-CTR)

- 1) 카운터 블록 생성(C_{tri}): Nonce 뒤에 숫자 $i(0,1,2..)$ 를 붙임.
- 2) 키스트림 생성(S_i): 카운터 블록을 AES로 암호화
$$S_i = E_{TK}(C_{tri})$$
- 3) XOR 연산(암호화): 평문(P)과 키스트림(S)을 XOR함.
$$C = P \oplus S$$

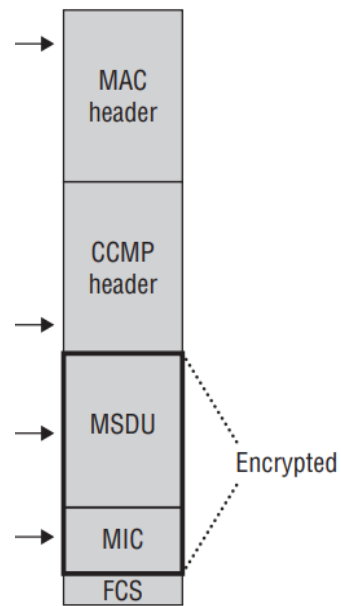
이때, 데이터 뿐만 아니라 MIC도 함께 암호화함.

CCMP

B. 암호화 프로세스

Step 5. 최종 프레임 조립

- 최종적으로 전송되는 패킷(MPDU)의 구조는 다음과 같다.
 - 1) MAC Header – 24~32 bytes
 - 2) CCMP Header – 8 bytes, Key ID + PN
 - 3) Encrypted Data
 - 4) Encrypted MIC – 8 bytes
 - 5) FCS – 4 bytes, CRC-32



CCMP

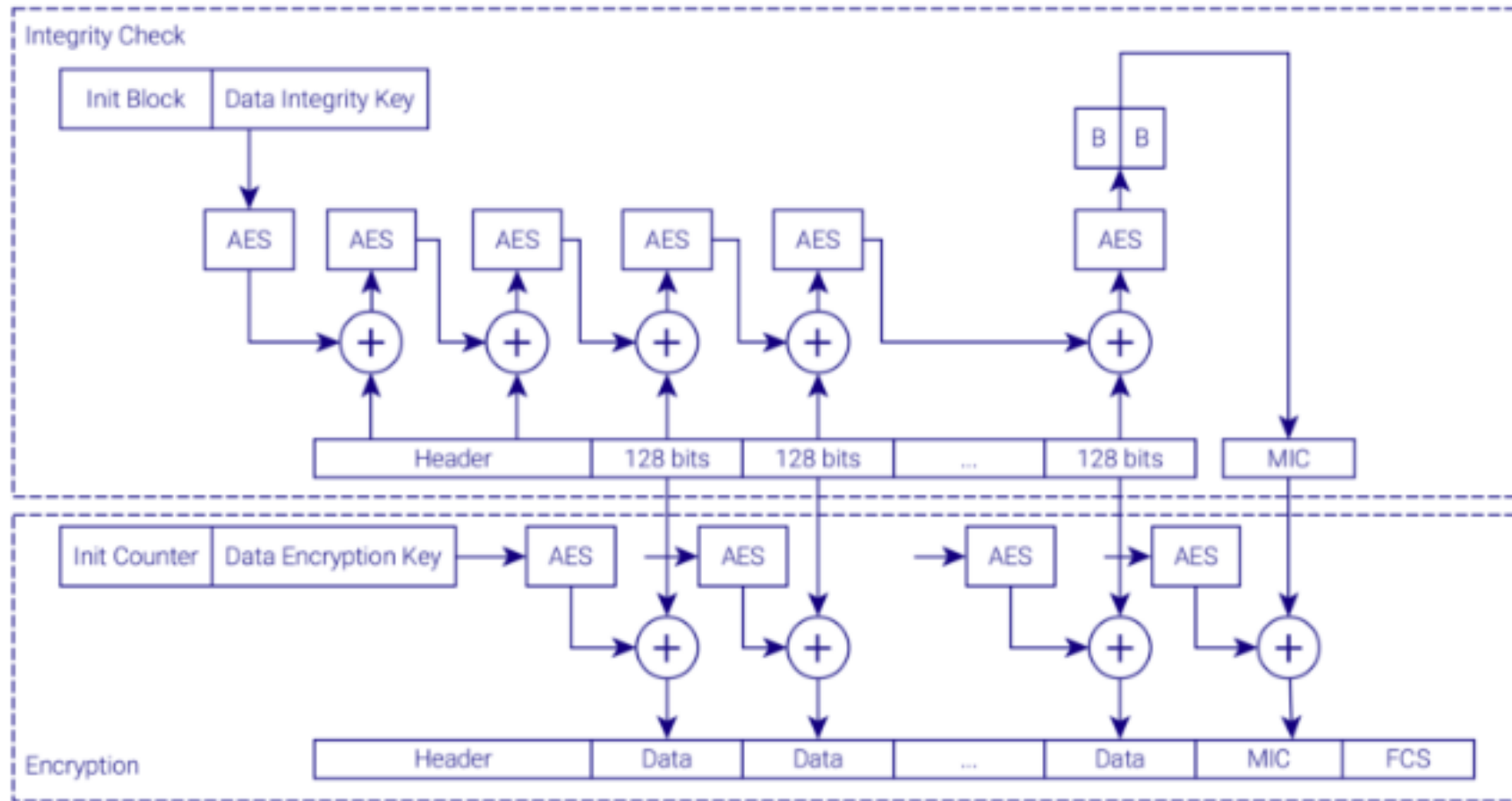
C. 기술적 특징

1. CCM 구조 – MIC도 함께 암호화되어 해커가 볼 수 없음
2. 병렬 처리 – CTR 모드의 특징 덕분에 암호화할 때 병렬 가능
3. 재전송 공격 방어 – PN을 확인하여 순서에 안 맞으면 폐기

D. 요약

$$\text{Ciphertext} = (\text{Plaintext} \parallel \text{MIC}) \oplus \text{AES}_{\text{TK}}(\text{Counter})$$

CCMP



Offline Dictionary Attack

- WPA2의 취약점
 - 1) MIC이 노출됨
 - 2) Nonce가 평문으로 전송됨.
- PTK를 만드는 공식에서 Password만 모르므로, 사전에 있는 정보를 Password 자리에 일일이 넣어보면서 캡처한 MIC과 일치하는지를 계속 확인하면 Password를 알아낼 수 있음.

$$PTK = PRF(PMK, ANonce, SNonce, AA, SPA)$$

Offline Dictionary Attack

- 공격 시나리오

1. 정찰: 피해자 탐색
2. 강제 연결 해제 – 4-way Handshake 유도
3. $\text{Msg1}(\text{Anonce})$ 과 $\text{Msg2}(\text{Snonce} + \text{MIC})$ 를 가로챈
4. 오프라인 대입 – 사전 대입 공격으로 비밀번호를 찾음.

Offline Dictionary Attack

- 방어법

1. 강력한 비밀번호 사용 – 사전에 없는 복잡한 단어 사용
2. WPA3 도입 - SAE는 MIC이 노출되지 않음.

WPA3

- IEEE 802.11ax
- GCMP-256 사용 – 무결성 검사(MIC)를 병렬 수행 가능
- 핵심 알고리즘: AES (256-bit key)
- 작동 모드: GCM(Galois Mode + Counter Mode)
 - CTR(Counter Mode): 기밀성 -> 데이터 암호화 (CCMP와 동일)
 - GMAC(Galois MAC): 무결성 -> 갈루아 필드 곱셈 연산 사용

GCMP

Step 1. 사전 준비(Setup)

1. Hash Subkey (H) 생성

- 암호화 키(K)로 '0'으로 채워진 블록을 AES 암호화함.
 - $H = E_K(0_{128})$
 - H는 무결성 검사(GHASH)에서 곱셈의 상수로 쓰임
- ### 2. Nonce (IV) 생성
- 12 bytes의 크기를 가지고, PN과 Address를 섞어서 만듦.

GCMP

Step 2. 데이터 암호화 (GCTR – Encryption)

- CCMP와 거의 똑같은 CTR 모드 사용

1. 초기 카운터 블록(J_0): Nonce 기반으로 시작 카운터를 만듦.

2. 카운터 증가(CB_i): J_0 에서 1씩 증가시킴($J_1, J_2, \dots$)

3. 암호화 (C)

- 평문(P)과 AES로 암호화된 카운터($E_K(CB_i)$)를 XOR함.

- $C_i = P_i \oplus E_K(CB_i)$

GCMP

Step 3. 무결성 검증 (GHASH – Integrity)

- CCMP와 다르게 chaining 없이 한 방에 계산.
- 갈루아 필드 연산: 데이터 블록들을 다항식의 계수로 보고, H(Hash Subkey)를 변수 x 로 본다.

$$GHASH(H, A, C) = X_1 \cdot H^m + X_2 \cdot H^{m-1} + \dots + X_m \cdot H^1$$

- A: AAD(헤더 정보)
- C: Ciphertext (암호문)
- 각 블록에 H의 거듭제곱만 곱해서 더하면 되므로, 병렬 처리가 가능해서 연산이 빠름.

GCMP

Step 4. 태그 생성

- $\text{Tag} = \text{GHASH}(H, A, C) \oplus E_k(J_0)$

CCMP vs. GCMP

구분

WPA2 (CCMP)

WPA3 (GCMP)

기반 모드

CCM (CTR + CBC-MAC)

GCM (CTR + GMAC)

무결성 방식

CBC-MAC (블록 체이닝)

GHASH (갈루아 필드 곱셈)

처리 방식

직렬 (Serial)

병렬 (Parallel)

(앞 블록 계산 끝나야 함)

(동시에 여러 블록 계산 가능)

속도 효율

하드웨어 가속 없으면 느림

소프트웨어로도 매우 빠름

키 길이

주로 128-bit

256-bit (Enterprise)

약점

오프라인 사전 공격 취약 (4-Way Handshake 시)

SAE로 사전 공격 원천 차단

Dragonfly Handshake (SAE)

- 비밀번호를 통신망으로 절대 보내지 않고(Zero-knowledge), 타원곡선 암호(ECC)를 이용해 서로 비밀번호를 알고 있다는 사실만 증명하는 기술

Dragonfly Handshake (SAE)

Phase 1. Hunting and Pecking

- 비밀번호를 먼저 타원곡선 위의 점(Point)으로 변환함.
 - 1) 입력: 비밀번호(PW) + 공유된 데이터(MACs) + 카운터(k)
 - 2) 해싱: $\text{Value} = \text{Hash}(\text{PW}, \text{MAC}_A, \text{MAC}_B, k)$
 - 3) 검증(Pecking): Value가 타원 곡선 방정식($y^2 = x^3 + ax + b$)를 만족하는 x좌표인지 확인
 - 4) 반복(Hunting):
곡선 위의 점이 아니라면? -> 카운터 k를 1 증가시키고 다시 해싱
곡선 위의 점이라면? -> 당첨! 그 점을 P로 확정.
 - 5) 결과: 해커가 패킷을 봐도 P가 무슨 비밀번호에서 왔는지 모름.

Dragonfly Handshake (SAE)

Phase 2. Commit & Confirm

- 구해진 점 P 와 각자 만든 Nonce를 이용해 핸드셰이크를 한다.

1) Commit:

각자 랜덤한 개인키 r 과 마스크 m 을 생성, 점 P 에 난수 처리를 하여 Commit Message를 만들어서 주고 받음.

2) Confirm: 서로 만든 키가 같은지 확인

Shared Secret (SS) 생성: $SS = r_A \times r_B \times P$

서로의 난수와 P 를 곱해서 공통의 비밀 값 SS 를 만듦(Diffie-Hellman 원리)

KCK & PMK 생성: SS 를 해시하여 생성.

HMAC 교환하여 서로 검증 -> PMK 생성 완료

4-way Handshake vs. SAE

비교 항목

WPA2 (4-Way Handshake)

WPA3 (SAE / Dragonfly)

핵심 재료

PMK (비밀번호 그 자체)

P (비밀번호로 유도된 타원곡선 점)

패킷 내용

난수(Nonce) + MIC(정답지)

난수(Random)가 섞인 연산값

오프라인 공격

가능 (치명적)

불가능 (완벽 방어)

MIC를 기준으로 무한 대입 가능

1번의 추측을 위해선 실시간 통신 필요

순방향 비밀성

없음

있음 (PFS)

(Forward Secrecy)

나중에 비번 털리면 과거 패킷 다 풀림

비번 털려도 과거 통신 내용 복구 불가

난수 의존도

Nonce는 재전송 방지용일 뿐

난수(r)가 키 생성의 핵심 (매번 바뀜)

감사합니다.

- 2주차 요약: 802.11의 암호화 방식의 발전, 공격 기법들
- 3주차 계획: 공격 방법 학습 및 실습

Reference

- CWSP Study Guide